

ISO/IEC 42001 : 2023

EDICIÓN 2026

LA GUÍA EJECUTIVA

# Gobernar la inteligencia *artificial.*

---

*Guía de referencia para Compliance, IT, riesgos y dirección general en LATAM sobre ISO/IEC 42001, el primer estándar internacional certificable para sistemas de gestión de inteligencia artificial.*

SELLO / REFERENCIA



ONCE  
MÉXICO®

CERTEZA HECHA NORMA.

ISO/IEC

42001

SISTEMA DE GESTIÓN DE IA

COLOFÓN

# Una guía editorial sobre gobernanza algorítmica.

---

EDICIÓN

2026 · v1.0 · Distribución pública

---

EDITOR

ONCE México · Organismo de certificación

---

AUDIENCIA

Compliance, IT, Riesgos y dirección general en LATAM

---

SITIO

[oncemexico.org](https://oncemexico.org)

---

© 2026 ONCE México. Todos los derechos reservados. Queda prohibida su reproducción total o parcial sin autorización escrita del titular.

El contenido tiene fines informativos y educativos; no constituye asesoría legal, regulatoria, de cumplimiento ni de implementación para ninguna organización. Las referencias a costos, tiempos y resultados son estimaciones orientativas de referencia del mercado.

**Nota de independencia.** ONCE México es un organismo de certificación. Sus actividades de auditoría y certificación se mantienen independientes de cualquier actividad de formación, y ONCE México no diseña, implementa ni asesora la implementación de sistemas de gestión en las organizaciones que certifica, conforme a los principios de imparcialidad de ISO/IEC 17021-1.

---

*Este documento ha sido preparado para ser leído como una conversación: rigurosa pero accesible, técnica pero útil.*

CONTENIDO

# El orden de las cosas.

Siete capítulos que van del contexto de adopción de IA en LATAM a tres casos reales de implementación de ISO 42001 en la región.

|    |                                                                                                                              |         |
|----|------------------------------------------------------------------------------------------------------------------------------|---------|
| 00 | <b>Introducción · Por qué necesitas leer esto</b><br>La pregunta que nadie quiere responder · IA en LATAM · Mapa regulatorio | 04 – 07 |
| 01 | <b>Qué es ISO 42001 — y qué no es</b><br>Definición ejecutiva · Cronología · Tres mitos que frenan la adopción               | 08 – 10 |
| 02 | <b>Quién debe certificarse</b><br>Seis sectores con mayor urgencia · Criterios mínimos · Autodiagnóstico                     | 11 – 14 |
| 03 | <b>Relación con ISO 27001, 27701 y otras normas</b><br>Ecosistema normativo · Matriz comparativa · El efecto multiplicador   | 15 – 17 |
| 04 | <b>Los 10 controles clave que pide la norma</b><br>Del inventario de sistemas a la mejora continua del SGIA                  | 18 – 22 |
| 05 | <b>Roadmap de implementación a 6 meses</b><br>Las seis fases · Proyección de inversión · Equipo interno mínimo               | 23 – 25 |
| 06 | <b>Cinco errores comunes — y cómo evitarlos</b><br>Patrones de fracaso observados en proyectos LATAM                         | 26 – 27 |
| 07 | <b>Escenarios ilustrativos de mercado</b><br>Fintech México · Healthtech Colombia · Programa público en Perú                 | 28 – 29 |
| →  | <b>Tus próximos pasos</b><br>Tres rutas de acción según tu nivel de madurez · Sobre ONCE México                              | 30      |

## INTRODUCCIÓN

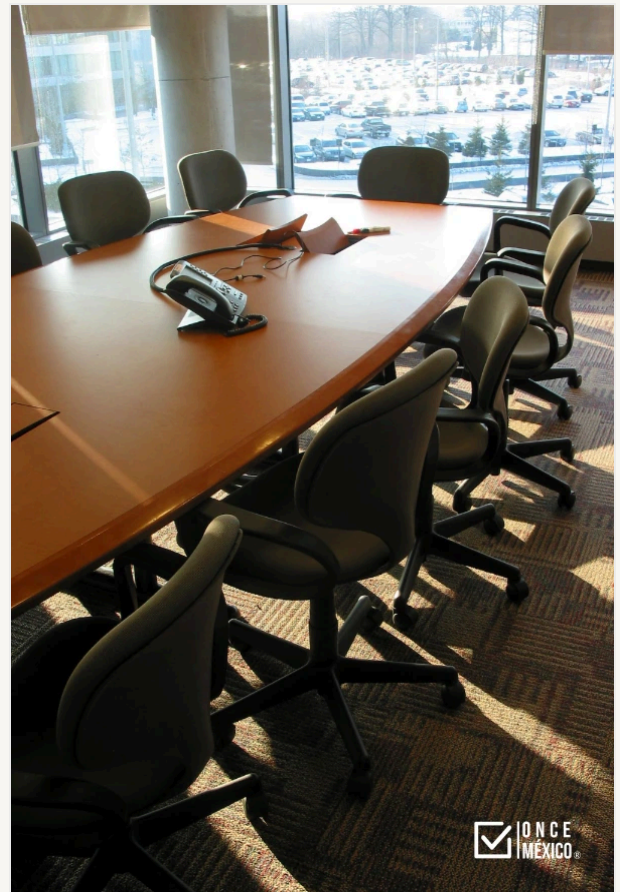
# Por qué necesitas *leer esto*.

*Imagina que el modelo de IA que tu empresa implementó para aprobar créditos, seleccionar proveedores o asignar recursos toma hoy una decisión incorrecta. La prensa lo detecta. El regulador llama. El consejo exige explicaciones.*

---

## ¿Quién firma la *responsabilidad*?

Si tu respuesta es *"no lo tenemos claro"*, no estás solo. La gran mayoría de las organizaciones latinoamericanas que ya operan IA en sus procesos críticos no tienen una respuesta documentada, auditada y defendible.



Saben que usan IA. Pero **no la gestionan** de forma responsable, trazable y gobernada. Esa brecha —entre *"usamos IA"* y *"la gestionamos con criterios corporativos claros"*— es exactamente el problema que este ebook está diseñado para ayudarte a cerrar.

No con teoría abstracta. Con un marco internacional concreto, aplicable hoy, independientemente del país donde opere tu empresa o de qué tan avanzada esté tu regulación local.

IA EN LATAM

# El crecimiento *que ya no se puede ignorar.*

La inteligencia artificial dejó de ser una promesa futurista en América Latina. Es una realidad operativa presente en los sectores más relevantes de la economía regional.

La velocidad de adopción superó la velocidad de la gobernanza. Y eso es un riesgo corporativo de primer nivel.

FINTECH

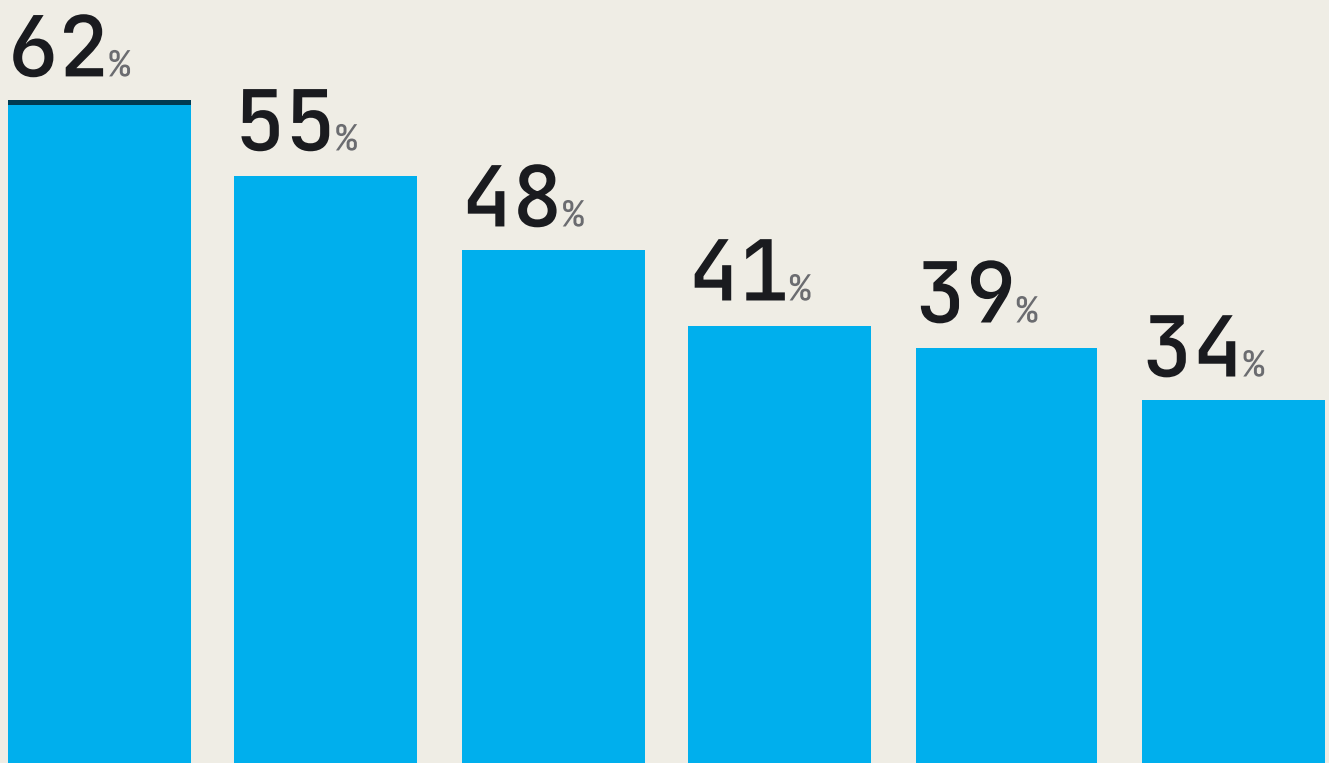
RETAIL

SALUD

EDTECH

SEGUROS

GOBIERNO



MÉXICO • FINTECH

Más del 62 % de las empresas del sector financiero usan modelos automatizados: scoring crediticio, detección de fraude en tiempo real, onboarding KYC.

COLOMBIA • SALUD

Diagnóstico asistido con velocidad de adopción que superó cualquier proyección pre-pandemia. Imágenes, triaje y predicción de readmisiones.

CHILE / PERÚ • ESTADO

Modelos de asignación de recursos y servicios ciudadanos que procesan millones de registros sin intervención humana directa.

MAPA REGULATORIO

# Lo que se viene *y por qué no puedes esperar.*

El mundo regulatorio en torno a la IA está en construcción acelerada, y las organizaciones latinoamericanas con operaciones internacionales ya sienten sus efectos.

2024

## EU AI Act — Unión Europea

VINCULANTE • 2024

Primer marco regulatorio integral sobre IA a nivel mundial. Clasifica los sistemas por nivel de riesgo (mínimo, limitado, alto, prohibido) y establece obligaciones de transparencia, supervisión humana y documentación técnica para cada categoría.

2023

## NIST AI RMF — Estados Unidos

VOLUNTARIO • REFERENCIA

Marco de gestión de riesgos del Instituto Nacional de Estándares y Tecnología. No es vinculante, pero se convirtió en el estándar de facto para contratos con el gobierno estadounidense y para *due diligence* corporativo en M&A tecnológicos.

2025+

## LATAM — Avances legislativos

EN CONSTRUCCIÓN

México, Colombia, Brasil y Argentina con proyectos en distintas etapas. Brasil lidera con una propuesta federal avanzada; México avanza desde el INAI y la CNBV; Colombia incorpora criterios de IA ética en su supervisión financiera.

### EL HALLAZGO

Esperar a que tu gobierno termine de legislar es, en sí mismo, una *decisión de riesgo corporativo*.

El problema no es la falta de regulación. Es **el tiempo que tarda en llegar**. Legislar toma años. Los riesgos operativos, reputacionales y contractuales de operar IA sin gobernanza son inmediatos.

Denominador común en LATAM: caminan hacia la obligatoriedad de *documentar, auditar y rendir cuentas* sobre IA en decisiones que afectan a personas.

ISO/IEC 42001 • DICIEMBRE 2023

# El primer marco de gestión de IA *certificable a nivel internacional.*

En diciembre de 2023, la Organización Internacional de Normalización publicó el primer estándar internacional para el establecimiento, implementación, mantenimiento y mejora continua de un Sistema de Gestión de Inteligencia Artificial — **SGIA**.

## NATURALEZA

### Estándar de adopción voluntaria

Desarrollado por expertos de más de 60 países, aplicable a cualquier organización de cualquier sector que use IA, independientemente de tamaño, madurez o ubicación.

## VENTAJA ESTRATÉGICA

### Anticipa la regulación que viene

No esperas a que la Cámara apruebe una ley ni a que tu regulador emita un lineamiento. Implementas. Certificas. Y cuando la regulación llegue, tu organización ya estará preparada, documentada y auditada.

## RESULTADO

### Ventaja competitiva real

Las organizaciones que actúan con anticipación se posicionan mejor para responder a la regulación que viene, fortalecer la confianza de clientes y socios, y diferenciarse en procesos de contratación que cada vez más exigen gobernanza de IA.

---

No tienes que esperar.  
*Puedes implementarla hoy.*

→ ESTE EBOOK ES TU MAPA PARA CONVERTIRTE EN UNA DE ESAS ORGANIZACIONES.

## 01

## CAPÍTULO UNO

# Qué es ISO 42001 — *y qué no es.*

*Si le preguntas a diez directivos latinoamericanos qué es ISO/IEC 42001, nueve te darán una respuesta incompleta. No porque sean negligentes — porque la norma es nueva y la mayoría de los contenidos disponibles están escritos para ingenieros, no para tomadores de decisiones.*

## 1.1

**Definición ejecutiva**

Lo que realmente hace la norma — sin tecnicismo innecesario.

## 1.2

**Cronología**

De ISO 9001 a 42001: la evolución de la gestión empresarial.

## 1.3

**Desmitificación**

Tres mitos que frenan la adopción en los consejos directivos.



1.1 • DEFINICIÓN EJECUTIVA

# Lo que realmente *hace* la norma.

*ISO/IEC 42001 define los requisitos para que una organización establezca, implemente, mantenga y mejore continuamente un Sistema de Gestión de Inteligencia Artificial — abreviado como SGIA.*

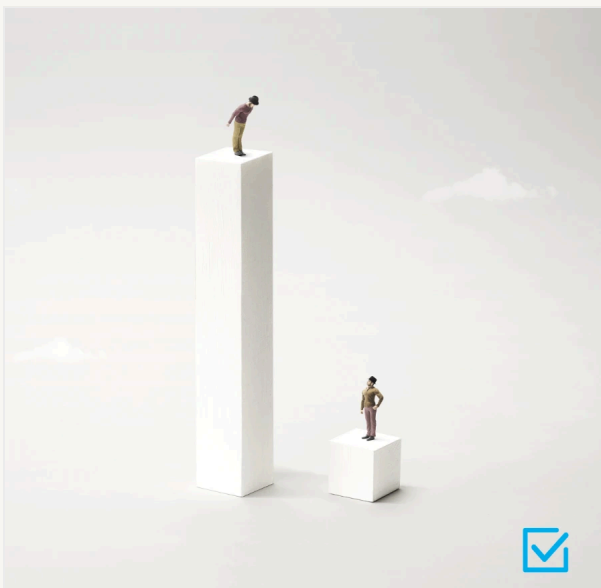
## Traducido al lenguaje de negocios

La norma te ayuda a documentar cómo tu empresa usa la IA de forma responsable, desde quién toma las decisiones sobre cada modelo, hasta cómo se auditan los resultados, qué pasa cuando algo falla y cómo garantizas que tus sistemas no discriminen, manipulen ni operen fuera de los límites que tú mismo te has impuesto.

## Lo que *no* evalúa

No evalúa si tu algoritmo es bueno o malo desde el punto de vista técnico. No mide la precisión de tu modelo ni la calidad de tu código.

Lo que evalúa es si tu organización tiene los procesos, políticas, roles y controles necesarios para gestionar responsablemente cualquier sistema de IA dentro de su alcance definido.



### LA DISTINCIÓN FUNDAMENTAL

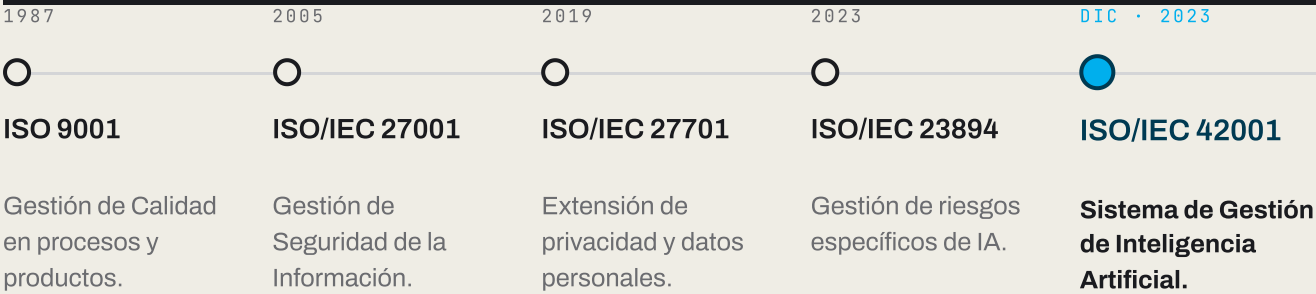
El objeto de la norma *no es tu tecnología.*  
Es tu gobernanza.

Una organización puede tener el algoritmo más sofisticado y reprobado la auditoría si no puede demostrar quién lo aprobó, cómo se monitorea y qué pasa cuando falla.

1.2 • CRONOLOGÍA

# De dónde viene y por qué ahora.

*Para entender la relevancia de ISO 42001, ayuda verla dentro de la evolución histórica de los estándares de gestión empresarial.*



## No fue un evento aislado.

La publicación de diciembre de 2023 fue la respuesta estructurada de la comunidad normativa internacional a una realidad que ya no podía ignorarse: las organizaciones adoptaban IA a una velocidad que sus marcos de gestión existentes no podían absorber.

EL ESLABÓN QUE FALTABA

**ISO 27001** gestiona la seguridad de la información que alimenta los modelos.  
**ISO 27701** protege la privacidad de los datos personales que los modelos procesan.  
Pero ninguna respondía a la pregunta central de la era de la IA:

¿Cómo gestionas *el sistema que toma las decisiones?*

1.3 • DESMITIFICACIÓN

# Tres mitos *que frenan la adopción.*

*La confusión alrededor de la norma no es accidental — es el resultado natural de un estándar nuevo en un mercado que aún no lo comprende bien. Estos son los tres malentendidos más frecuentes en las salas de dirección de LATAM.*

01

EL MITO

"Es obligatoria por ley — nos van a multar si no la tenemos."

LA REALIDAD

Es un estándar de **adopción voluntaria**. Ningún gobierno de LATAM la exige actualmente por ley. Sin embargo, la demanda comercial y contractual la está volviendo obligatoria *de facto*: clientes corporativos, licitaciones gubernamentales y socios internacionales ya la solicitan como requisito de negocio.

02

EL MITO

"Es solo para empresas de tecnología o startups de IA."

LA REALIDAD

Aplica a **cualquier organización que use IA**, sin importar el giro: una aseguradora con modelos de riesgo, un hospital con diagnóstico asistido, una cadena de retail con precios dinámicos, una entidad pública con asignación algorítmica de subsidios. Si usas IA en decisiones que afectan a personas, la norma es para ti.

03

EL MITO

"Certifica si nuestros algoritmos son correctos o éticos."

LA REALIDAD

**No evalúa algoritmos individuales.** Evalúa el Sistema de Gestión completo: políticas, roles, procesos de auditoría, mecanismos de transparencia y protocolos de respuesta ante incidentes. Es posible tener un modelo avanzado y no certificarse por falta de gobernanza — y viceversa.

## 02

## CAPÍTULO DOS

# Quién debe *certificarse.*

*La norma es universal en su diseño, pero no todas las organizaciones tienen la misma urgencia. Algunos sectores en LATAM ya enfrentan riesgos materializados — en forma de demandas, sanciones regulatorias o crisis reputacionales — mientras otros están a meses de enfrentarlos.*

2.1

Seis sectores con mayor  
urgencia en LATAM

012

2.2

Criterios corporativos  
mínimos

2.3

Autodiagnóstico rápido  
en cinco preguntas

2.1 · ANÁLISIS SECTORIAL

# Los seis sectores con *mayor* *urgencia*.

*Tres sectores que ya enfrentan reguladores activos. Tres que están a un escalón de hacerlo. El denominador común: todos toman decisiones que afectan directamente a personas.*



01 · SECTOR FINANCIERO

## Fintech / Banca

Credit scoring, detección de fraude, KYC automatizado, chatbots de atención.

**Reto:** Justificar algorítmicamente las decisiones de crédito ante reguladores (CNBV, SFC, SBIF) y ante clientes rechazados.

**Por qué urge:** Los reguladores financieros de MX, CO y CL ya exigen explicabilidad en modelos de crédito. La certificación ofrece evidencia independiente y reconocida de que el proceso de gobernanza es auditable.



02 · SALUD DIGITAL

## Healthtech

Diagnóstico asistido por imagen, triaje automatizado, predicción de readmisiones, análisis de expedientes clínicos.

**Reto:** Garantizar seguridad del paciente, proteger datos de salud — los más sensibles en cualquier jurisdicción — y cumplir con exigencias de hospitales y aseguradoras.

**Por qué urge:** Los contratos con hospitales privados y aseguradoras de salud en LATAM empiezan a exigir gobernanza formal de IA como requisito de *due diligence*. Un fallo sin documentación genera responsabilidad civil directa.



03 · SECTOR PÚBLICO

## Gobierno

Asignación de subsidios sociales, seguridad predictiva, gestión de trámites ciudadanos, análisis de riesgo fiscal.

**Reto:** Transparencia y rendición de cuentas ante la ciudadanía cuando algoritmos toman decisiones que afectan derechos sociales.

**Por qué urge:** Los órganos de control (ASF en México, CGR en Chile y Colombia) ya auditan el uso de tecnología en decisiones públicas. La gobernanza documentada es una de las defensas institucionales más sólidas.

2.1 · ANÁLISIS SECTORIAL

# Tres sectores a un escalón de la regulación.

*Educación, seguros y retail comparten una característica: usan IA en decisiones que ya están bajo escrutinio creciente de consumidores, reguladores y áreas de adquisiciones.*



04 · EDUCACIÓN

## EdTech

Personalización de rutas de aprendizaje, predicción de deserción, evaluación automatizada, recomendación de contenido.

**Reto:** Proteger datos de menores, evitar sesgos en evaluación y garantizar que las recomendaciones algorítmicas no amplifiquen brechas educativas.

**Por qué urge:** Las plataformas que operan en instituciones públicas o privadas están sujetas a regulaciones de protección de datos de menores. El sesgo en evaluación genera impugnaciones y pérdida de contratos institucionales.



05 · ASEGURADORAS

## Seguros

Cálculo automatizado de primas, evaluación de siniestros por IA, detección de fraude en reclamaciones, *underwriting* automatizado.

**Reto:** Demostrar que los modelos de *pricing* no discriminan por características protegidas (género, origen étnico, condición médica) ante reguladores y demandas civiles.

**Por qué urge:** Escrutinio creciente sobre discriminación en *pricing*. La certificación es la herramienta que permite demostrar que los modelos fueron diseñados, validados y monitoreados con criterios de equidad documentados.



06 · COMERCIO

## Retail / E-commerce

Motores de recomendación personalizada, precios dinámicos automáticos, gestión predictiva de inventario, detección de fraude.

**Reto:** Transparencia en precios dinámicos ante reguladores de competencia y confianza del consumidor en recomendaciones personalizadas.

**Por qué urge:** COFECE (MX) y CADE (BR) ya investigan prácticas de fijación de precios algorítmica. Los consumidores y las marcas exigen cada vez más transparencia sobre cómo funcionan los motores de recomendación.

**Característica compartida:** los seis sectores toman decisiones que afectan directamente a personas — clientes, pacientes, ciudadanos, empleados — y todas esas decisiones generan responsabilidades legales, reputacionales y éticas que sus marcos de gobernanza actuales no están preparados para gestionar.

2.2 • CRITERIOS MÍNIMOS

# ¿Está lista *tu* organización?

No todas las organizaciones están listas para iniciar un proyecto ISO 42001 hoy — y eso está bien. La norma tiene requisitos de madurez organizacional mínima que conviene validar antes de comprometer presupuesto.

## 01

### Tamaño y estructura

Más de 50 colaboradores con al menos un área formal de IT, Compliance, Riesgos o Auditoría Interna. No requiere departamento de IA — sí la estructura mínima para asignar roles de gobernanza.

## 02

### Uso activo de IA

Al menos un sistema de IA — propio o de un tercero — que impacta decisiones sobre clientes, empleados, proveedores o ciudadanos. No basta con "explorar IA" o pilotos sin impacto externo.

## 03

### Sponsor ejecutivo

Un *sponsor* de nivel directivo (C-Level o reporte directo) con autoridad para impulsar el proyecto, asignar recursos y tomar decisiones sobre el alcance del SGIA.

2.3 • AUTODIAGNÓSTICO RÁPIDO

## Cinco preguntas *sin investigación previa*.

01

¿Usas al menos un sistema de IA que afecta directamente a personas (clientes, empleados, ciudadanos)?

02

¿Tienes documentado formalmente quién es responsable de cada sistema de IA?

03

¿Existe un proceso establecido para revisar y auditar los resultados de tus sistemas periódicamente?

04

¿Cuentas con un protocolo definido para actuar cuando un sistema produce resultados incorrectos o dañosos?

05

¿Informas activamente a los usuarios cuando una decisión que los afecta fue tomada por un sistema automatizado?

INTERPRETACIÓN DE RESULTADOS

5 SÍ • BASE SÓLIDA

El proyecto te llevará a formalizar y certificar lo que ya haces bien. Implementación significativamente más corta.

3 – 4 SÍ • FUNDAMENTOS PARCIALES

Un diagnóstico inicial identificará los *gaps* concretos. Estás en condiciones de iniciar con baja fricción.

1 – 2 SÍ • OPORTUNIDADES

El proyecto te dará los procesos y controles que hoy no tienes. Impacto en madurez proporcional al esfuerzo.

0 SÍ • URGENTE

Tu organización usa IA sin gobernanza formal. No es inusual en LATAM — pero es urgente atenderlo.

## 03

## CAPÍTULO TRES

# Cómo se relaciona con *ISO 27001, 27701 y otras normas.*

*ISO 42001 no compite con las normas que tu organización probablemente ya opera. Las complementa, las extiende y, en muchos casos, reutiliza directamente los controles, procesos y documentación que ya tienes.*

3.1

Ecosistema normativo

3.2

Matriz comparativa

3.3

El efecto multiplicador



3.1 – 3.2 • ECOSISTEMA Y MATRIZ

# No empiezas desde cero.

Las normas ISO comparten una arquitectura común — la Estructura de Alto Nivel (HLS) — que define cómo se organiza cualquier sistema de gestión. Esa arquitectura no es un detalle técnico menor: es la razón por la que una organización con ISO 27001 tiene 60–70 % del trabajo estructural de ISO 42001 prácticamente resuelto.

| NORMA                                        | ENFOQUE                                       | QUÉ APORTA A LA GESTIÓN DE IA                                                                                                                | INTEGRACIÓN CON 42001                                                                                                     |
|----------------------------------------------|-----------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------|
| ISO/IEC 27001<br>SEGURIDAD DE LA INFORMACIÓN | Protección de datos y activos de información. | Gestiona los riesgos de acceso no autorizado, fuga o manipulación de datos de entrenamiento y producción que alimentan los modelos de IA.    | Alto • ~70 %<br>Controles reutilizables o adaptables directamente.                                                        |
| ISO/IEC 27701<br>PRIVACIDAD DE DATOS         | Tratamiento de datos personales.              | Gestiona consentimiento, minimización y derechos del titular sobre los datos personales que los sistemas de IA procesan.                     | Alto<br>Extensión directa de 27001 — complementa transparencia y equidad.                                                 |
| ISO/IEC 23894<br>RIESGOS EN IA               | Guía técnica de riesgos de IA.                | Marco técnico de referencia para identificar, evaluar y tratar riesgos específicos: sesgo, opacidad, deriva del modelo, fallas de seguridad. | Muy alto<br>Funciona como par: una define <i>qué</i> , la otra <i>cómo</i> .                                              |
| ISO 9001<br>CALIDAD                          | Principios de mejora continua.                | Establece la mentalidad de proceso y ciclo PHVA que es la base cultural de cualquier sistema de gestión maduro.                              | Medio<br>Lógica de proceso ya instalada — se extiende al dominio de IA.                                                   |
| EU AI Act<br>REGULACIÓN EUROPEA              | Marco legal vinculante.                       | Obligaciones legales para sistemas de IA de alto riesgo: documentación técnica, supervisión humana y transparencia hacia usuarios.           | Estratégico<br>Apoya la preparación hacia el cumplimiento del EU AI Act; no sustituye la evaluación legal de conformidad. |

**Lo que ISO 42001 añade** es el dominio específico de la IA dentro de un marco ya existente: políticas de uso, inventario de sistemas, evaluación de impacto ético y técnico, controles de sesgo y transparencia. El resultado es un Sistema de Gestión Integrado bajo una misma lógica operativa.

3.3 • MENSAJE PARA EL C-LEVEL

# El efecto *multiplicador*.

*Si tu organización ya tiene ISO 27001, tiene una ventaja competitiva concreta para implementar ISO 42001 — y esa ventaja suele traducirse en una reducción significativa de esfuerzo y tiempo de preparación, un factor relevante al construir el caso de negocio.*

LO QUE YA TIENES — Y QUE SE REUTILIZA

**01 Gestión de riesgos.**

El proceso de identificación, evaluación y tratamiento de riesgos se extiende para incluir sesgo, opacidad y deriva de modelos — sin crear un proceso paralelo.

**02 Roles y responsabilidades.**

El CISO, el Comité de Seguridad y los responsables de activos ya definidos sirven como base para los nuevos roles de gobernanza de IA.

**03 Auditoría interna.**

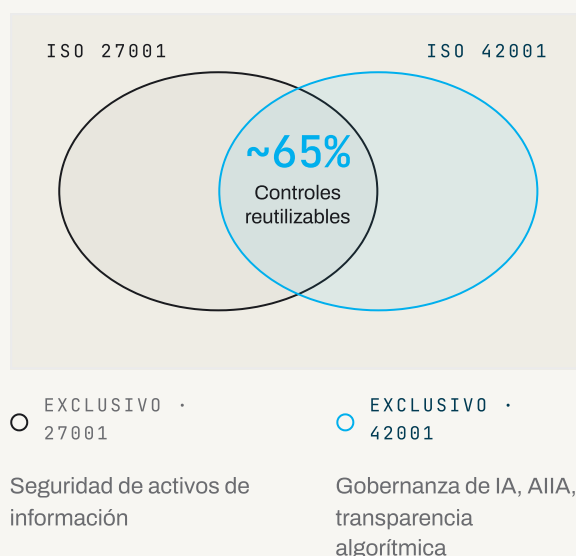
El programa, los criterios y la metodología de hallazgos y no conformidades son idénticos en estructura. Solo se amplía el alcance.

**04 Gestión documental.**

Las políticas, procedimientos y registros ya tienen un sistema de control establecido. ISO 42001 añade documentos específicos dentro del mismo marco.

**05 Cultura de mejora continua.**

El ciclo PHVA y la mentalidad de auditoría ya están instalados. Eso elimina la resistencia cultural — el mayor costo oculto de cualquier proyecto normativo.



**60 – 70 %**

reducción de esfuerzo de preparación  
frecuentemente estimada en torno a 60–70  
%, según el grado de madurez del sistema de  
gestión existente.

Un Sistema de Gestión Integrado que *multiplica el valor* de ambas certificaciones ante clientes, reguladores y socios comerciales.

# 04

## CAPÍTULO CUATRO

# Los 10 controles *que pide la norma.*

*ISO 42001 tiene más de 30 controles formales en su Anexo A. Pero en la práctica de implementación en LATAM, hay 10 pilares que concentran el 80 % del esfuerzo, el 80 % del valor y el 80 % de las preguntas que un auditor te hará.*

### RESUMEN • 10 CONTROLES CLAVE

- 01 Política de uso de IA
- 02 Inventario de sistemas de IA
- 03 Evaluación de Impacto (AIIA)
- 04 Roles y responsabilidades
- 05 Gestión de datos para entrenamiento
- 06 Monitoreo en producción
- 07 Gestión de incidentes de IA
- 08 Transparencia hacia usuarios
- 09 Auditoría de sesgo
- 10 Mejora continua (PHVA aplicado a IA)

→ LO QUE SIGUE ES LA LISTA QUE NECESITAS ENTENDER ANTES DE INICIAR CUALQUIER CONVERSACIÓN SOBRE IMPLEMENTACIÓN.

# Del marco a la *documentación*.

## 01

MARCO • POLÍTICA

### Política de uso de IA

**Qué exige:** Documentar formalmente qué usos están permitidos, restringidos o prohibidos. Aprobada por la alta dirección y revisada periódicamente.

EN EL DÍA A DÍA

Un banco que usa IA para credit scoring debe establecer explícitamente que ningún modelo puede rechazar crédito sin revisión humana disponible, que no pueden usar variables protegidas como proxy y que cualquier nuevo caso de uso pasa por aprobación antes de producción.

## 02

VISIBILIDAD • INVENTARIO

### Inventario de sistemas de IA

**Qué exige:** Registro formal, actualizado y centralizado de todos los sistemas de IA — incluidos los de terceros. Propósito, datos, impacto y responsable por entrada.

EN EL DÍA A DÍA

Una aseguradora descubre en su diagnóstico inicial que opera 14 sistemas con componentes de IA: el modelo de *pricing* que conocen, pero también el CRM con *scoring* automático, la plataforma de RRHH que filtra CVs, el motor anti-fraude y tres herramientas de productividad con IA generativa que los equipos adoptaron por su cuenta.

## 03

ANÁLISIS • AIIA

### Evaluación de Impacto (AIIA)

**Qué exige:** Para sistemas de IA que toman decisiones de alto impacto, evaluación formal de riesgos éticos, técnicos y sociales: sesgo, impacto en grupos vulnerables, privacidad, fallos y supervisión humana requerida.

EN EL DÍA A DÍA

Una plataforma EdTech que implementa un sistema de recomendación para preparatoria debe evaluar si el algoritmo podría amplificar brechas de aprendizaje, qué pasa con estudiantes de necesidades especiales y qué mecanismo tiene el maestro para cuestionar la recomendación. Esa evaluación se documenta antes de producción.

# De los datos *a la operación.*

## 04

ESTRUCTURA • ROLES

### Roles y responsabilidades

**Qué exige:** Definir formalmente quién diseña, aprueba, opera, audita y tiene autoridad para suspender cada sistema. Personas nombradas — no áreas genéricas.

EN EL DÍA A DÍA

En una healthtech colombiana, el modelo de diagnóstico asistido tiene una ficha que especifica: el Dr. Ramírez como responsable clínico, la Ing. Torres como responsable técnica, el Comité de Ética como instancia de aprobación y el Director Médico con autoridad de suspensión. Cuando algo anómalo ocurre, todos saben qué hacer.

## 05

ORIGEN • DATOS

### Gestión de datos para entrenamiento

**Qué exige:** Documentar y controlar los datos usados para entrenar y validar modelos: calidad, representatividad, ausencia de sesgos documentados y consentimiento de titulares cuando corresponda.

EN EL DÍA A DÍA

Una fintech que entrena su *credit scoring* con datos de 2015–2022 debe revisar si esos datos sobrerrepresentan ciertos perfiles, si reflejan decisiones pasadas ya identificadas como discriminatorias y si los clientes otorgaron consentimiento explícito para ese uso. Si no — reentrenar o documentar limitaciones.

## 06

OPERACIÓN • MONITOREO

### Monitoreo en producción

**Qué exige:** Monitorear sistemas en producción para detectar *drift*, comportamientos inesperados, cambios en la distribución de datos y desviaciones respecto al desempeño aprobado.

EN EL DÍA A DÍA

Un sistema de detección de fraude en e-commerce monitorea semanalmente la tasa de falsos positivos. Cuando una campaña genera un patrón inusual, el equipo recibe una alerta automática, documenta el evento como posible *drift* y activa el protocolo de revisión antes de que afecte la experiencia o los ingresos.

# De la respuesta *a la equidad.*

## 07

### RESPUESTA • INCIDENTES

#### Gestión de incidentes de IA

**Qué exige:** Protocolo documentado y probado para responder cuando un sistema produce resultados incorrectos, dañinos o que generan reclamaciones. Detección, contención, comunicación a afectados y prevención de recurrencia.

### EN EL DÍA A DÍA

Una aseguradora descubre que su modelo rechazó automáticamente 340 reclamaciones legítimas en 3 semanas. El protocolo define: en 2 h suspender modelo y activar revisión manual, en 24 h notificar a los 340 clientes, en 72 h reportar al regulador si supera umbrales, y en 30 días documentar análisis de causa raíz y acciones correctivas.

## 08

### COMUNICACIÓN • USUARIOS

#### Transparencia hacia usuarios

**Qué exige:** Cuando una decisión que afecta a una persona fue tomada o asistida por un sistema automatizado, informarlo de forma clara. En casos de alto impacto, acceso a explicación comprensible de los factores que influyeron.

### EN EL DÍA A DÍA

Un banco que rechaza una solicitud de crédito no puede simplemente enviar "*su solicitud fue rechazada*". El comunicado debe indicar que la decisión fue asistida por un sistema automatizado, mencionar los principales factores y informar al solicitante sobre su derecho a revisión humana. En la UE ya es obligación legal; la CNBV avanza en lineamientos similares.

## 09

### EQUIDAD • SESGO

#### Auditoría de sesgo

**Qué exige:** Evaluar periódicamente que los sistemas no producen resultados sistemáticamente diferentes para grupos protegidos (género, edad, origen étnico, condición socioeconómica, discapacidad) de forma injustificada.

### EN EL DÍA A DÍA

Una plataforma de reclutamiento que filtra CVs realiza trimestralmente un análisis comparando tasas de avance por género, edad y origen. Cuando detecta que mujeres entre 25–35 tienen una tasa de rechazo 18 puntos mayor con credenciales equivalentes, Data Science investiga si alguna variable actúa como proxy del género y ajusta el modelo.

# El sistema *no termina al certificarse.*

## 10

CICLO • MEJORA CONTINUA

### Mejora continua — PHVA aplicado a IA

**Qué exige:** El SGIA no termina con la certificación. Requiere un ciclo estructurado de **Planear • Hacer • Verificar • Actuar** aplicado continuamente: revisar efectividad de controles, incorporar lecciones aprendidas, actualizar inventario y ajustar políticas cuando el contexto regulatorio o tecnológico cambia.

EN EL DÍA A DÍA

Una vez al año, el Comité de Gobernanza de IA realiza una revisión formal del SGIA: cuántos sistemas se añadieron al inventario, cuántos incidentes ocurrieron y su severidad, si las políticas siguen siendo adecuadas dado el avance tecnológico y qué mejoras se implementarán en el siguiente ciclo. Esa revisión es evidencia para la auditoría de recertificación.

#### P • PLANEAR

Política de uso, alcance del SGIA, evaluación de impacto inicial.

#### H • HACER

Implementar controles, capacitar personal, operar el sistema.

#### V • VERIFICAR

Monitoreo, auditoría interna, revisión de indicadores.

#### A • ACTUAR

Correcciones, mejoras del sistema, actualización del inventario.

#### SÍNTESIS DEL CAPÍTULO 04

Los 10 controles concentran el *80 % del esfuerzo* y el *80 % del valor* que un auditor te exigirá demostrar.

Política y alcance • Inventario y AIIA • Roles y datos  
• Monitoreo y respuesta • Transparencia y equidad  
• Mejora continua.

#### Lo que el auditor te preguntará primero

¿Quién aprobó este sistema? ¿Dónde está documentado? ¿Cómo se monitorea? ¿Qué pasa cuando falla? ¿A quién le rinde cuentas?

Si tu organización puede responder estas cinco preguntas con evidencia documentada por cada sistema, la auditoría de certificación está, en sustancia, ganada.

# 05

CAPÍTULO CINCO

## Roadmap de implementación a 6 meses.

Así se estructuran típicamente los proyectos de implementación: seis fases con tiempos e hitos. ONCE México certifica el sistema; no lo implementa ni asesora su implementación. Este mapa ayuda a la dirección a dimensionar el esfuerzo antes de iniciar.

|    |                                                                                                                                            |               |
|----|--------------------------------------------------------------------------------------------------------------------------------------------|---------------|
| 01 | <b>Diagnóstico inicial (Gap Analysis)</b><br>Informe de brechas: qué existe, qué falta, qué requiere crearse. Alcance preliminar del SGIA. | 2 — 3<br>SEM  |
| 02 | <b>Definición del alcance del SGIA</b><br>Documento de alcance aprobado: qué sistemas, qué unidades de negocio, qué geografías.            | 1 — 2<br>SEM  |
| 03 | <b>Diseño conceptual y documentación</b><br>Política aprobada, inventario completo, estructura documental, evaluaciones de impacto.        | 4 — 6<br>SEM  |
| 04 | <b>Implementación operativa de controles</b><br>10 controles operando · personal capacitado · registros de monitoreo · simulacro probado.  | 8 — 10<br>SEM |
| 05 | <b>Auditoría interna</b><br>Informe con hallazgos y plan de correctivas. Organización lista para auditoría externa.                        | 2 SEM         |
| 06 | <b>Auditoría de certificación (3ª parte)</b><br>Etapas 1 (documental) y 2 (en sitio). Cierre de no conformidades. Certificado emitido.     | 3 — 5<br>SEM  |

Organizaciones con ISO 27001 reducen las Fases 1 y 3 entre 30 y 40 % gracias a la infraestructura documental y de gestión ya existente.

DURACIÓN TOTAL

18 — 24 sem.

Desde el diagnóstico inicial hasta la emisión del certificado.



5.2 · PROYECCIÓN DE INVERSIÓN 2026

# Lo que cuesta — *y lo que devuelve.*

| PERFIL ORGANIZACIONAL                                                                     | RANGO DE INVERSIÓN<br>TOTAL | DURACIÓN    | CONDICIÓN DE PARTIDA                                                                                                        |
|-------------------------------------------------------------------------------------------|-----------------------------|-------------|-----------------------------------------------------------------------------------------------------------------------------|
| <b>Mediana</b><br>50 — 200 empleados · 3<br>— 8 sistemas · sin ISO<br>previa              | <b>\$280 — 420 k</b><br>MXN | 20 — 24 sem | Parte desde cero en gobernanza de IA. ROI vía nuevos contratos + reducción de prima de seguro cibernético.                  |
| <b>Mediana con ISO 27001</b><br>50 — 200 empleados · 3<br>— 8 sistemas                    | <b>\$160 — 260 k</b><br>MXN | 16 — 20 sem | Infraestructura documental y de auditoría reutilizable. Mismo ROI con inversión incremental significativamente menor.       |
| <b>Grande / Corporativo</b><br>200 — 500+ empleados ·<br>10+ sistemas · sin ISO<br>previa | <b>\$520 — 850 k</b><br>MXN | 22 — 28 sem | Mayor complejidad y coordinación interdepartamental. Contratos corporativos e institucionales de alto valor.                |
| <b>Grande / Corp. con ISO 27001</b><br>200 — 500+ empleados ·<br>10+ sistemas             | <b>\$320 — 520 k</b><br>MXN | 18 — 24 sem | Reutilización de estructura de gestión existente. ROI acelerado por menor costo y tiempo de llegada al mercado certificado. |

5.3 · EQUIPO INTERNO MÍNIMO

## El equipo que se suele movilizar.

|                                                                                                                                                                                                                                       |                                                                                                                                                                                                                             |                                                                                                                                                                                                                   |                                                                                                                                                                                                                                      |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p>ROL 1 · 30 — 40 %</p> <p><b>Responsable de Gobernanza de IA</b></p> <p>CISO, Director de Compliance, Chief Data Officer o perfil híbrido. Coordina el proyecto, opera el sistema en el largo plazo y aprueba la documentación.</p> | <p>ROL 2 · 10 — 15 %</p> <p><b>Apoyo Legal</b></p> <p>Revisión de la política de uso de IA y definición de protocolos de transparencia hacia usuarios. Un abogado con experiencia en derecho tecnológico es suficiente.</p> | <p>ROL 3 · 20 — 35 %</p> <p><b>Apoyo Técnico IT / Data Science</b></p> <p>Ingenieros y científicos de datos construyen el inventario, documentan datos de entrenamiento y diseñan el monitoreo en producción.</p> | <p>HABILITADOR · SPONSOR</p> <p><b>Sponsor ejecutivo C-Level</b></p> <p>Sin respaldo visible, los proyectos mueren en la Fase 3 cuando los equipos técnicos perciben la documentación como una distracción de su trabajo "real".</p> |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

**Para el caso de negocio:** las organizaciones suelen evaluar el retorno en tres dimensiones — acceso a contratos y licitaciones que exigen gobernanza de IA, mejores condiciones potenciales de aseguramiento cibernético, y menor exposición a incidentes. La magnitud varía según el contexto y no puede garantizarse.

# 06

## CAPÍTULO SEIS

# Cinco errores que matan el proyecto.

*La mayoría de los fracasos no son técnicos. No fallan porque la norma sea difícil de entender ni porque los controles sean imposibles de implementar — fallan por decisiones organizacionales que se toman en las primeras semanas y que son muy costosas de corregir después.*

## 01

### EL ERROR

### Redactar políticas antes de hacer el diagnóstico

Descargar plantillas de internet y declarar "documentación lista" sin haber mapeado la operación real. La política prohíbe usos que ya ocurren, permite los que deberían restringirse y no menciona los sistemas más críticos.

### LA SOLUCIÓN PREVENTIVA

El diagnóstico es la Fase 1 por una razón estructural: sin él no puedes escribir nada relevante. Dos semanas mapeando sistemas, decisiones y responsables. La política que escribas después será defendible porque describe tu realidad — no una aspiracional.

## 02

### EL ERROR

### Implementar desde Compliance aislando a IT y Data Science

Compliance desarrolla toda la documentación, define los controles y diseña los procesos sin involucrar a los equipos técnicos que realmente operan los sistemas. Resultado: un sistema que sobre el papel cumple, pero que nadie del área técnica conoce ni siente como propio.

### LA SOLUCIÓN PREVENTIVA

Comité de Gobernanza de IA desde la semana 1 con Compliance, IT, Data Science y Legal — reuniones quincenales durante toda la implementación. Los controles técnicos se diseñan **con** los equipos técnicos, no **para** ellos.

## 03

### EL ERROR

### Tratar la norma como un checklist administrativo estático

Pasar la auditoría y declarar el proyecto terminado. El SGIA existe en documentos pero no en operación: nadie actualiza el inventario, nadie analiza registros, el protocolo nunca se prueba.

### LA SOLUCIÓN PREVENTIVA

Define el SGIA como un sistema vivo con ciclo operativo anual explícito: revisión de dirección anual, actualizaciones trimestrales del inventario, revisiones semestrales de evaluaciones de impacto, un simulacro anual de incidentes. Asigna estas actividades en los objetivos de desempeño del Responsable de Gobernanza.

# El alcance que *no estás viendo*.

## 04 EL ERROR • SHADOW AI

### Subestimar el alcance real de la IA

El inventario se hace solo con IT y Data Science: aparecen 5 sistemas conocidos. Lo que nadie detecta: RRHH usa una plataforma de reclutamiento SaaS con filtros algorítmicos, comercial adoptó un CRM con scoring automático, atención usa un chatbot con IA generativa, y cuatro equipos más usan herramientas con IA integrada que procesan información confidencial.

LA SOLUCIÓN PREVENTIVA

Inventario con **tres fuentes**: consulta técnica a IT/DS, encuesta estructurada a todos los líderes de área (¿qué herramientas usas que tomen decisiones automáticas o filtren información sin intervención humana?) y revisión del catálogo de suscripciones SaaS. El Shadow AI representa frecuentemente 40 — 60 % del inventario real de una organización mediana.

## 05 EL ERROR • DUPLICACIÓN

### Duplicar controles en vez de integrarlos con ISO 27001

Crear un sistema de gestión completamente independiente: nuevos documentos, políticas, procesos de auditoría, registros, comité. El resultado es duplicación burocrática que confunde a los equipos, aumenta costo de mantenimiento y genera inconsistencias entre marcos.

LA SOLUCIÓN PREVENTIVA

ISO 42001 fue diseñada para **integrarse, no duplicarse**. Extender el SGSI existente: ampliar el alcance, añadir documentos específicos dentro del mismo sistema documental, extender el programa de auditorías y ampliar el comité para incluir gobernanza de IA. El resultado es un Sistema de Gestión Integrado que ambos auditores pueden revisar en una misma visita.

| #  | ERROR                                   | IMPACTO PRINCIPAL                                   | SOLUCIÓN PREVENTIVA                                               |
|----|-----------------------------------------|-----------------------------------------------------|-------------------------------------------------------------------|
| 01 | Políticas antes del diagnóstico         | Documentación que no refleja la realidad operativa. | Diagnóstico primero, documentación después — siempre.             |
| 02 | Compliance aislado de IT y Data Science | Sistema que existe en papel pero no en la práctica. | Comité de Gobernanza multidisciplinario desde el día 1.           |
| 03 | SGIA como checklist estático            | Sistema que falla en la recertificación.            | Ciclo operativo anual con responsables y objetivos asignados.     |
| 04 | Shadow AI fuera del inventario          | Incidentes en sistemas no monitoreados.             | Inventario con tres fuentes: IT, encuesta de área, catálogo SaaS. |
| 05 | Duplicar controles de ISO 27001         | Burocracia, confusión e inconsistencias.            | Extender el SGI existente — no crear uno paralelo.                |

# 07

CAPÍTULO SIETE

## Escenarios ilustrativos de mercado.

Tres escenarios representativos contruidos a partir de patrones observados en el mercado. Las organizaciones y las cifras son ilustrativas; no representan clientes específicos ni resultados atribuibles a los servicios de certificación de ONCE México.

CASO 01 • FINTECH MÉXICO

300 EMPLEADOS

### Cuando el regulador llama y el algoritmo *no puede hablar*.



#### EL CONTEXTO

Fintech con 180,000 créditos activos procesados por un modelo de scoring propio con 40+ variables. La tasa de morosidad era buena. La aprobación, en 3 minutos.

Lo que no tenían: ningún mecanismo documentado para explicar cómo decidían, quién aprobó el modelo o qué pasaba con quien consideraba injusto el resultado.

#### EL RETO

Q1 2024: la CONDUSEF recibió **847 reclamaciones** por rechazos percibidos como arbitrarios o discriminatorios. Solicitaron documentación técnica del modelo — no existía.

En paralelo, tres bancos corporativos negociaban alianzas estratégicas y exigían evidencia de gobernanza formal de IA como condición de cierre.

#### LA SOLUCIÓN

Diagnóstico de emergencia (2 sem) que mapeó **7 sistemas de IA**. Proyecto a dos velocidades: respuesta inmediata para CONDUSEF (6 sem) e implementación ISO 42001 completa (16 sem).

Énfasis en AIIA del scoring (identificó 3 proxies de género y origen), política de transparencia y auditoría trimestral de sesgo.

EN ESTE ESCENARIO ILUSTRATIVO • 12 MESES • CIFRAS ILUSTRATIVAS

**\$45 M**

en contratos cerrados con 3 alianzas bancarias en los 30 días posteriores al certificado.

**312**

créditos aprobados tras revisión humana de las 847 reclamaciones — ingresos adicionales directos.

**−78 %**

reducción de reclamaciones por percepción de discriminación en el trimestre siguiente a la corrección.

**Cierre**

de la revisión regulatoria de CONDUSEF sin sanción económica. Tasa de morosidad estable.

CASO 02 • HEALTHTECH COLOMBIA

150  
EMPLEADOS •  
MEDELLÍN

## La certificación que abrió las puertas *de los hospitales.*

### CONTEXTO

Software de diagnóstico asistido por imagen con sensibilidad del 94 %. Tecnología sólida, contratos con 4 clínicas medianas. El problema: los hospitales grandes no podían contratar sin gobernanza auditada.

### RETO

Tres licitaciones perdidas en 2023 — no por precio, sino por no demostrar gobernanza formal. Una aseguradora nacional exigió certificación de tercera parte antes del 30 de junio de 2025.

### SOLUCIÓN

Proyecto de 18 sem priorizando 4 controles: trazabilidad de datos de entrenamiento, formalización del rol del radiólogo, protocolo de incidentes clínicos y transparencia de confianza del modelo.

### RESULTADO

**+340 %**

en ingresos recurrentes mensuales tras el contrato con la aseguradora nacional. Tres hospitales que rechazaron en 2023, firmaron en 2025.



CASO 03 • SECTOR PÚBLICO PERÚ

2.3 M  
FAMILIAS •  
PROGRAMA  
NACIONAL

## Gobernanza de IA como respuesta a *la crisis de legitimidad.*

### CONTEXTO

Programa Nacional de Transferencias Sociales con scoring algorítmico. Tiempo de procesamiento: de 45 a 7 días. Costo administrativo: -23 %. Operativamente, un éxito.

### RETO

2H 2023: investigación periodística reveló que comunidades indígenas tenían tasas de rechazo consistentemente más altas. Defensoría del Pueblo y Contraloría iniciaron auditorías. Crisis de legitimidad institucional.

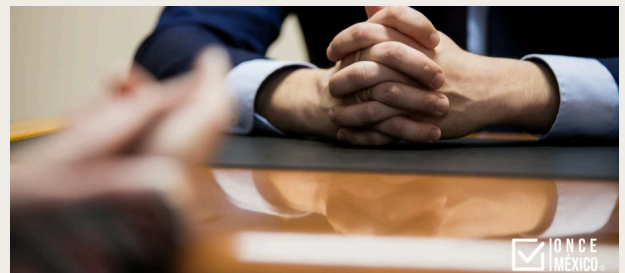
### SOLUCIÓN

Auditoría de sesgo con panel independiente (academia + organizaciones indígenas). Tres variables actuaban como proxies de la brecha digital urbano-rural. Modelo rediseñado y reentrenado. Transparencia ciudadana implementada.

### RESULTADO

**87 k**

familias adicionales incorporadas al programa, previamente excluidas por sesgo. Brecha de rechazo: de 31 a <4 puntos.



La equidad y el desempeño del modelo *no son objetivos incompatibles*. La experiencia del mercado sugiere que ambos pueden mejorarse de forma conjunta, sin que uno sacrifique al otro.

TUS PRÓXIMOS PASOS

# La pregunta ya no es si la necesitas.

*Es cuál es tu siguiente paso concreto — y eso depende del punto en que está tu organización hoy. Elige tu ruta.*

El mundo no va a esperar a que tu organización esté lista para gobernar su IA.

*Las ventajas competitivas las acumulan los que actúan primero.*

RUTA 01

## Sesión informativa sobre certificación

30 minutos con nuestro equipo para conocer el proceso de certificación ISO/IEC 42001: sus etapas, requisitos y alcance. Sin costo, sin compromiso.

SIN COSTO

**Agenda tu sesión →**

RUTA 02

## Foundation Autoestudio PECB

Curso autogestivo con certificación PECB Foundation en ISO/IEC 42001. Materiales de estudio, evaluación y certificado internacional. Disponible en español.

CERTIFICACIÓN

INTERNACIONAL

**Inscríbete ahora →**

RUTA 03

## Lead Implementer PECB · 4 meses

Programa de formación para profesionales que liderarán la implementación del SGIA en su organización. Impartido por instructores certificados PECB. Formación independiente del proceso de certificación.

CONTACTO DIRECTO

**Solicita información →**

La formación y la certificación se mantienen independientes: participar en cursos no influye en las decisiones de auditoría ni de certificación (ISO/IEC 17021-1).

EDITOR

## ONCE México

Organismo de certificación especializado en certificaciones de gobernanza de datos, seguridad de la información e IA. 25 años · 200+ organizaciones certificadas en LATAM.



CERTEZA HECHA NORMA.

oncemexico.org

© 2026 · CERTEZA HECHA NORMA